

Shoplus 应用授权流程需求文档

面向 Shoplus 平台研发团队：实现第三方应用授权流程，向 SendMast 安全发放店铺级访问密钥

版本：v1.1 日期：2026-06-30

文档目标	定义 Shoplus 需要提供的第三方应用授权流程，使商家可以在 Shoplus 中确认授权，并让 SendMast 后端安全获取店铺级访问密钥。
阅读对象	Shoplus 平台研发、开放平台负责人、SendMast 对接研发。
范围说明	本文只描述应用授权、应用凭证和店铺级访问密钥发放流程。
优先级	P0：应用创建、授权跳转、授权回调、code 换取店铺级访问密钥、取消授权后的密钥失效。

1. 背景与目标

- SendMast 需要以第三方应用身份接入 Shoplus，代表已授权商家访问其店铺相关 OpenAPI。
- 当前缺少标准应用授权流程，商家无法在 Shoplus 后台确认授权，SendMast 也无法安全获得店铺级访问密钥。
- 本需求要求 Shoplus 提供应用授权机制：平台分配应用凭证，商家授权后回调 SendMast，SendMast 后端用一次性 code 换取店铺级访问密钥。

2. 角色与核心概念

概念	说明
SendMast 应用	Shoplus 为 SendMast 创建的第三方应用，拥有 app_id、app_key、app_secret。
商家	Shoplus 店铺管理员，负责确认是否授权 SendMast 访问其店铺。
授权码 code	商家确认授权后生成的一次性短期凭证，只能由 SendMast 后端换取访问密钥。
店铺级访问密钥 access_token	SendMast 后续调用 Shoplus OpenAPI 的凭证，必须绑定到具体店铺和授权范围。
state	SendMast 生成并在回调中校验的随机值，用于防止 CSRF 和串单。

3. Shoplus 需要提供的应用凭证

Shoplus 需要先为 SendMast 创建一个第三方应用，并安全提供以下信息。

字段	必填	说明
app_id	是	应用的内部唯一 ID。
app_key 或 client_id	是	授权入口和签名请求中使用的公开应用标识。
app_secret	是	只提供给 SendMast 后端保存，用于签名换取访问密钥，不能暴露到浏览器。
authorization_url	是	商家授权入口 URL。
token_url	是	SendMast 后端用 code 换 access_token 的接口 URL；也可在回调参数中返回。
redirect_uri 白名单	是	Shoplus 必须校验回调地址，只允许预先登记的 SendMast callback。

4. 总体授权流程

步骤	动作	责任方	说明
1	商家在 SendMast 点击 “连接 Shoplus 店铺”	SendMast	SendMast 生成 state，并跳转到 Shoplus 授权入口。
2	商家登录 Shoplus 并确认授权	Shoplus	展示应用名称、权限范围、授权店铺、隐私说明。
3	Shoplus 回调 SendMast	Shoplus	携带 code、state，可选携带 token_url。
4	SendMast 后端换取访问密钥	双方	SendMast 使用 app_secret 对请求签名，调用 token_url 换取 access_token。
5	SendMast 保存连接关系	SendMast	保存店铺 ID、店铺名称、OpenAPI 地址、access_token、授权范围。

5. 授权入口要求

5.1 请求参数

参数	必填	说明
app_key 或 client_id	是	Shoplus 分配给 SendMast 的应用标识。
redirect_uri	是	授权成功后的回调地址，必须匹配 Shoplus 后台白名单。
state	是	SendMast 生成的随机字符串，Shoplus 回调时必须原样返回。
scope	是	请求权限范围，例如 read_store、read_customers、read_orders。
response_type	建议	固定为 code，便于后续兼容 OAuth 风格。

5.2 URL 示例

GET https://admin.shoplus.com/oauth/authorize
?app_key=SENDMAST_APP_KEY
&redirect_uri=https%3A%2F%2Fapp.sendmast.com%2Fintegrations%2Fshoplus%2Fcallback
&state=RANDOM_STATE
&scope=read_store,read_customers,read_orders
&response_type=code

6. 授权确认页面要求

Shoplus 需要在商家确认授权前展示清晰的授权页面，避免商家误授权。页面至少包含：

- 应用名称：SendMast。
- 应用说明：邮件营销与店铺自动化。
- 授权店铺：展示当前将要授权的店铺名称和店铺 ID。

- 权限范围：用商家可理解的语言展示 scope 对应能力。
- 操作按钮：确认授权、取消授权。
- 安全提示：授权后 SendMast 将获得访问该店铺相关数据的密钥。

7. 授权回调要求

7.1 成功回调

参数	必填	说明
code	是	一次性授权码，建议 5-10 分钟内有效，仅可使用一次。
state	是	必须与授权入口中的 state 完全一致。
token_url	否	如果 token 接口不是固定地址，可在回调中返回完整 token_url。

302 Location: https://app.sendmast.com/integrations/shoplus/callback?code=AUTH_CODE&state=RANDOM_STATE&token_url=https%3A%2F%2Fopenapi.shoplus.com%2Foauth%2Ftoken

7.2 失败或拒绝授权回调

302 Location: https://app.sendmast.com/integrations/shoplus/callback?error=access_denied&error_description=merchant_cancelled&state=RANDOM_STATE

8. code 换取访问密钥接口

8.1 请求方式

项目	要求
Method	建议 POST；如果 Shoplus 已有网关规范，也可以支持 GET。
Endpoint	固定 token_url 或回调中返回的 token_url。
Content-Type	application/json。
调用方	只能由 SendMast 后端调用，不能由浏览器直接调用。
超时	建议 15 秒内返回。

8.2 请求参数

参数	必填	说明
app_key 或 client_id	是	Shoplus 分配给 SendMast 的应用标识。
code	是	授权回调得到的一次性授权码。

参数	必填	说明
timestamp	是	Unix 秒，用于防重放。
nonce	是	随机字符串，用于防重放。
signature_method	是	建议 HMAC-SHA256 或 HMAC-SHA1，双方固定即可。
sign	是	使用 app_secret 生成的签名。

9. 签名算法建议

为降低接入复杂度，建议 Shoplus 使用如下签名方式。若 Shoplus 已有开放平台签名规范，也可以使用现有规范，但需提供明确文档和测试用例。

1. 收集所有请求参数，排除 sign 字段。
2. 按参数名进行字典序排序。
3. 使用 RFC3986 对 key 与 value 编码。
4. 按 k=v 形式用 & 拼接为签名原文。
5. 使用 app_secret 做 HMAC，建议 HMAC-SHA256，输出 base64 或 hex。
6. Shoplus 服务端使用相同算法验签，并校验 timestamp 与 nonce。

签名原文示例：

app_key=SENDMAST_APP_KEY&code=AUTH_CODE&nonce=abc123×tamp=1782816000

sign = HMAC_SHA256(app_secret, 签名原文)

10. token 接口成功响应

返回结果必须能让 SendMast 建立“租户账号 - Shoplus 店铺 - 访问密钥”的绑定关系。

```
{
  "code": 0,
  "msg": "success",
  "trace_id": "req_20260630_001",
  "data": {
    "access_token": "STORE_LEVEL_ACCESS_TOKEN",
    "token_type": "Bearer",
    "expires_at": 1798761600,
    "refresh_token": "OPTIONAL_REFRESH_TOKEN",
    "scope": ["read_store", "read_customers", "read_orders"],
    "openapi_base_url": "https://openapi.shoplus.com",
    "store": {
      "id": "123456",
      "name": "Demo Store",
      "shop_domain": "demo.shoplus.net",
      "main_domain": "www.demo.com",
      "timezone": "Asia/Shanghai"
    },
    "app": {
      "id": "shoplus_app_id",
      "key": "SENDMAST_APP_KEY",
```

```
"name": "SendMast"
},
"merchant_user": {
  "id": "merchant_user_id",
  "name": "Merchant Admin"
}
}
}
```

10.1 字段说明

字段	必填	说明
access_token	是	店铺级访问密钥，SendMast 后续调用 OpenAPI 使用。
expires_at	建议	密钥过期时间。若长期有效，可为空，但必须支持商家取消授权后立即失效。
refresh_token	可选	如果 access_token 会过期，建议提供刷新令牌。
openapi_base_url	是	该店铺后续 OpenAPI 请求的基础地址。
store.id	是	店铺唯一 ID，用于防止同一店铺绑定到多个 SendMast 租户。
store.name	是	店铺名称，用于 SendMast 页面展示。
store.main_domain	建议	店铺真实访问域名，用于邮件按钮链接。

11. 错误响应要求

场景	HTTP 状态	业务 code	处理要求
code 无效、过期或已使用	400	invalid_code	SendMast 提示重新授权。
redirect_uri 不匹配	400	invalid_redirect_uri	拒绝授权或拒绝换 token。
签名错误	401	invalid_signature	拒绝请求，并返回 trace_id 便于排查。
timestamp 或 nonce 无效	401	invalid_request_time	拒绝重放请求。
商家取消授权	302 回调	access_denied	SendMast 显示用户取消。
后续 access_token 失效	401	token_revoked	SendMast 将店铺标记为授权失效，引导重新授权。

12. 后续 OpenAPI 鉴权要求

本文不定义具体业务接口，但 access_token 的使用方式需要固定，便于 SendMast 后续接入。

Header	必填	说明
Authorization	是	Bearer <access_token>。
Accept	是	application/json。
Content-Type	写接口 必填	application/json。

当商家取消授权、应用被禁用、密钥过期或权限不足时，Shoplus 必须返回明确错误，尤其是 401 token_revoked，方便 SendMast 引导商家重新授权。

13. 授权生命周期要求

- Shoplus 后台应提供“已授权应用”列表，商家可查看 SendMast 的授权状态、授权店铺、授权时间、权限范围。
- 商家可主动取消授权；取消后 access_token 和 refresh_token 必须立即失效。
- 如果应用权限发生变化，建议要求商家重新确认授权。
- 如果 access_token 有有效期，Shoplus 需要提供 refresh_token 刷新机制；如果没有有效期，必须保证取消授权后即时失效。
- 同一店铺重复授权时，Shoplus 可以复用原授权，也可以发放新 access_token，但旧 token 的处理规则必须明确。

14. 安全要求

- app_secret 只允许服务端保存和使用，不能出现在前端页面、URL、日志或回调参数中。
- code 必须短期有效且一次性使用。
- token 接口必须校验 redirect_uri、app_key、code、timestamp、nonce、sign。
- 建议对 token 接口做 IP、频率和失败次数限制。
- 所有授权与换 token 失败都需要返回 trace_id，方便双方排查。
- Shoplus 日志中应记录应用 ID、店铺 ID、商家用户 ID、授权时间、取消授权时间。

15. 验收标准

编号	验收项	通过标准
A1	应用创建	Shoplus 能向 SendMast 提供 app_id、app_key、app_secret、authorization_url、token_url。
A2	授权跳转	SendMast 跳转 Shoplus 后，商家可看到应用名称、店铺和权限范围。

编号	验收项	通过标准
A3	授权回调	商家确认后，Shoplus 回调 redirect_uri，并携带 code 与原始 state。
A4	防 CSRF	SendMast 校验 state 成功；state 不匹配时绑定失败。
A5	签名换 token	SendMast 后端使用 app_secret 签名后，可通过 code 换取 access_token。
A6	一次性 code	同一 code 第二次使用必须失败。
A7	密钥可用	使用 access_token 能调用 Shoplus 基础 OpenAPI，例如获取店铺信息。
A8	取消授权	商家取消授权后，旧 access_token 立即返回 401 token_revoked。

16. Shoplus 交付物

- 测试环境授权入口 URL。
- SendMast 测试应用的 app_id、app_key、app_secret。
- redirect_uri 配置方式和白名单规则。
- token_url 与签名算法文档。
- 成功响应、错误响应、token 失效响应示例。
- 一个可用于联调的测试商家账号和测试店铺。

文档结束。